

[Self-report I-01] Caller can underfund reentrancy probe gas stipend, bypassing it

Location: AtomicQueueDerailBeforeTransferHook:beforeTransfer

Summary

The beforeTransfer hook probes the AtomicQueue with `staticcall{ gas: DERAILED_GAS_STIPEND }` and treats empty revert data as "not reentrant". However, a probe that runs out of gas partway through its REENTRANCY revert also returns empty data. Under EIP-150, the probe receives at 63 /64 of the available gas, so a caller can limit its gas while retaining some which may be used to continue execution of the main transaction. In theory, an attacker could tune the gas limit of a transaction to bypass the hook.

Impact

Under certain circumstances, an attacker could run malicious `solve()` calls against users' latent vault share approvals to the AtomicQueue, and drain those shares as if the hook were not installed.

Currently, those circumstances are not possible. Underfunding the probe requires entering the hook with less than about 4.3k gas. The vault is then left with only about 65 gas to finish the transfer. The transfer reverts, and `solve()` reverts with it.

The viability of this attack is dependent on specific EVM gas costs which may change in a future upgrade.

Remediation

Commit 09990c9 adds a gas check before the probe, as defense in depth:

None

```
uint256 gasAvailable = gasleft();
if (gasAvailable - gasAvailable / 64 < DERAILED_GAS_STIPEND) {
    revert InsufficientGasForProbe(
        gasAvailable, DERAILED_GAS_STIPEND
    );
}
```

This guarantees that the probe always receives the full stipend which we have defined at the contract level.

We acknowledge that the same theoretical EVM upgrades we are protecting against could invalidate the stipend itself. However, we believe that a stipend of 8000 gas (suggested in https://github.com/PashovAuditGroup/PaxosLabs_September26_MERGED/issues/3) provides a reasonable margin of safety and we expect that any such upgrade would be publicised ahead of time, allowing us to deploy a new hook with a higher stipend.